

INFORME DE PENTESTING

Máquina **BASH_SUID** — Escalada de privilegios local

Abuso de binario con bit SUID (GNU bash)

Autor: **Josep Sanz**

Fecha: 4 de noviembre de 2026

Objetivo: 172.17.0.2

Clasificación: CONFIDENCIAL

1. Resumen ejecutivo

Durante la auditoría de la máquina **BASH_SUID** se identificó y explotó con éxito una **escalada de privilegios local** que permitió pasar de un usuario sin privilegios (`hacker`) a **root** (control total del sistema). El vector de ataque fue un binario de la shell **GNU bash copiado a `/opt/bash_suid` con el bit *SUID* activado y propiedad de root**. Al invocar bash con la opción `-p`, la shell conserva el *EUID* privilegiado en lugar de descartarlo, otorgando una sesión con permisos de root.

La explotación no requirió contraseñas, exploits de memoria ni herramientas sofisticadas: únicamente comandos nativos del sistema. El impacto es **crítico**, ya que compromete por completo la confidencialidad, integridad y disponibilidad del host.

Vulnerabilidad principal	Severidad	Resultado
Binario bash con bit SUID (privesc local)	**CRÍTICA**	Acceso root / lectura de `/root/flag.txt`

Ficha de la auditoría

Objetivo	BASH_SUID — 172.17.0.2
Tipo de prueba	Caja negra / escalada de privilegios local
Sistema operativo	Linux (Ubuntu / Debian-like)
Servicio expuesto	22/tcp — OpenSSH 8.9p1 (Ubuntu)
Flag obtenida	FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}
Autor del informe	Josep Sanz
Fecha	4 de noviembre de 2026

2. Detalle de la vulnerabilidad

Nombre	Escalada de privilegios mediante binario SUID (GNU bash)
CWE	CWE-250 (Execution with Unnecessary Privileges) / CWE-269 (Improper Privilege Management)
OWASP	A04:2021 – Insecure Design / Hardening deficiente del sistema
MITRE ATT&CK;	T1548.001 – Abuse Elevation Control Mechanism: Setuid and Setgid
CVSS 3.1	7.8 (Alta) — AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Referencia	GTFOBins — bash (SUID)

2.1. Descripción técnica

El **bit SUID** (*Set User ID*, permiso `-rwsr-xr-x`) hace que un ejecutable se lance con los privilegios de **su propietario** y no con los del usuario que lo invoca. Es un mecanismo legítimo para binarios concretos (por ejemplo `passwd`), pero aplicarlo a una **shell interactiva** es una configuración peligrosa: cualquier usuario puede obtener una sesión con los permisos del propietario del binario.

En este caso existía `/opt/bash_suid`, una copia de GNU bash 5.1 propiedad de **root** con el bit SUID activo. Por defecto, bash detecta que su *EUID* no coincide con su *UID* real y, por seguridad, descarta los privilegios al arrancar. Sin embargo, la opción `-p` (*privileged mode*) **le indica que NO abandone esos privilegios**, manteniendo el `euid=0`. El resultado es una shell efectiva como root.

2.2. Impacto

- **Confidencialidad (Alta):** lectura de cualquier fichero del sistema, incluidos `/etc/shadow` y `/root/flag.txt`.
- **Integridad (Alta):** modificación de ficheros de configuración, binarios, usuarios y credenciales.
- **Disponibilidad (Alta):** capacidad de detener servicios, borrar datos o inutilizar el host.
- **Persistencia:** posibilidad de crear puertas traseras o nuevos usuarios privilegiados.

3. Metodología y explotación paso a paso

A continuación se detalla la cadena completa, acompañada de las capturas de pantalla que sirven como evidencia de cada fase.

Paso 1 — Reconocimiento: escaneo de puertos (Nmap)

Se lanza un escaneo completo de puertos y servicios sobre el objetivo. Únicamente se encuentra abierto el puerto **22/tcp**, con **OpenSSH 8.9p1** sobre Ubuntu, confirmando que el acceso inicial a la máquina se realiza por SSH.

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

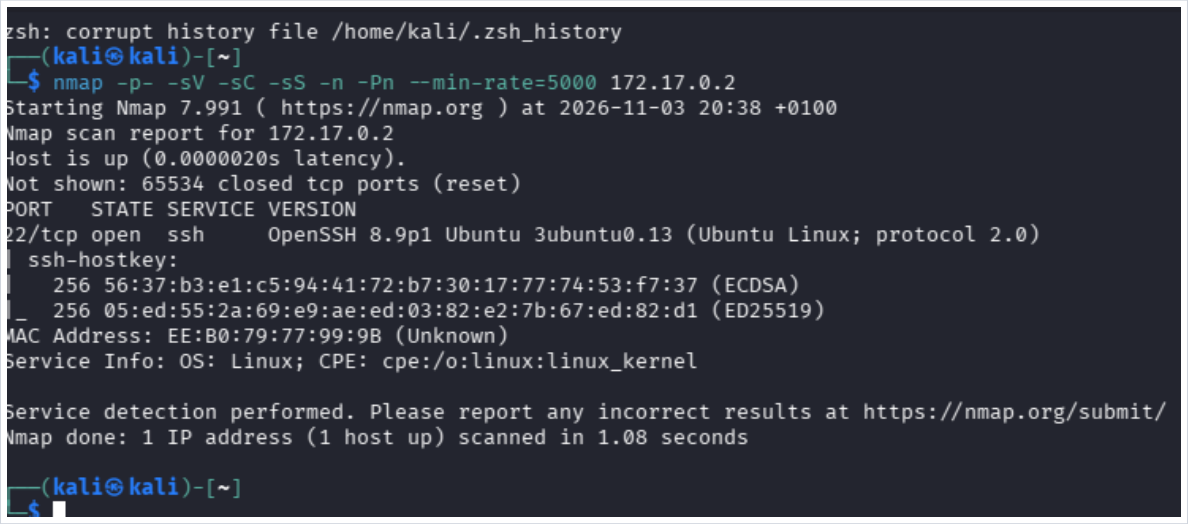


Figura 1. Escaneo Nmap: puerto 22/tcp abierto (OpenSSH 8.9p1).

Paso 2 — Enumeración local: búsqueda de binarios SUID

Una vez con una sesión como el usuario `hacker`, se enumeran los binarios con bit SUID en todo el sistema de ficheros. Entre los binarios habituales del sistema destaca una entrada anómala: `/opt/bash_suid`, que no forma parte de la instalación estándar.

```
find / -perm -4000 2>/dev/null
```

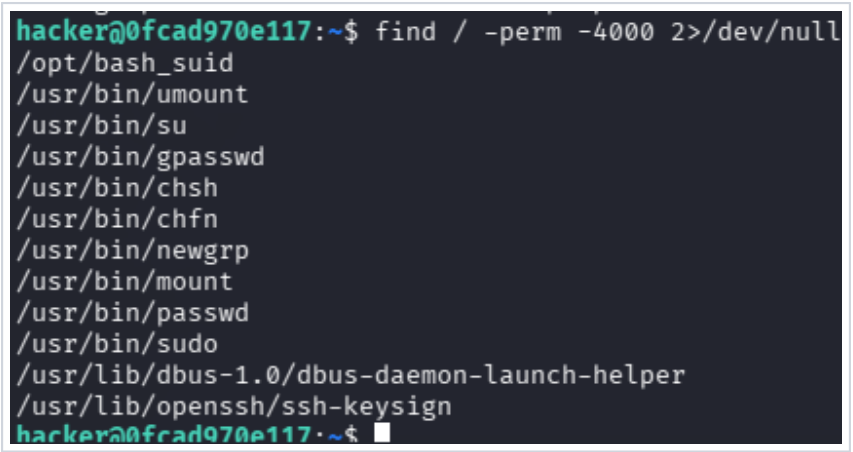


Figura 2. Binarios SUID. Se identifica /opt/bash_suid como candidato sospechoso.

Paso 3 — Prueba de ejecución (sin privilegios)

Al ejecutar el binario directamente, se obtiene una shell, pero bash descarta los privilegios: `id` y `whoami` siguen mostrando al usuario `hacker` (`uid=1000`). Esto confirma el comportamiento de seguridad por defecto de bash ante un EUID distinto del UID real.

```
/opt/bash_suid id whoami
```

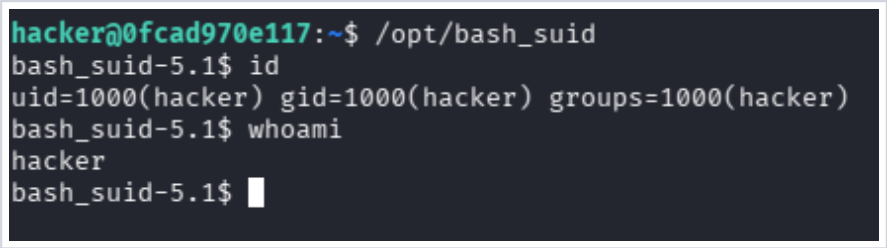


Figura 3. Ejecución directa: la shell no mantiene privilegios (uid=1000 hacker).

Paso 4 — Análisis de opciones del binario

Se consulta la ayuda del binario para localizar una opción que permita conservar los privilegios. Entre las opciones de invocación de bash figura `-p`, que activa el *modo privilegiado* e impide que la shell abandone el EUID heredado.

```
/opt/bash_suid --help
```

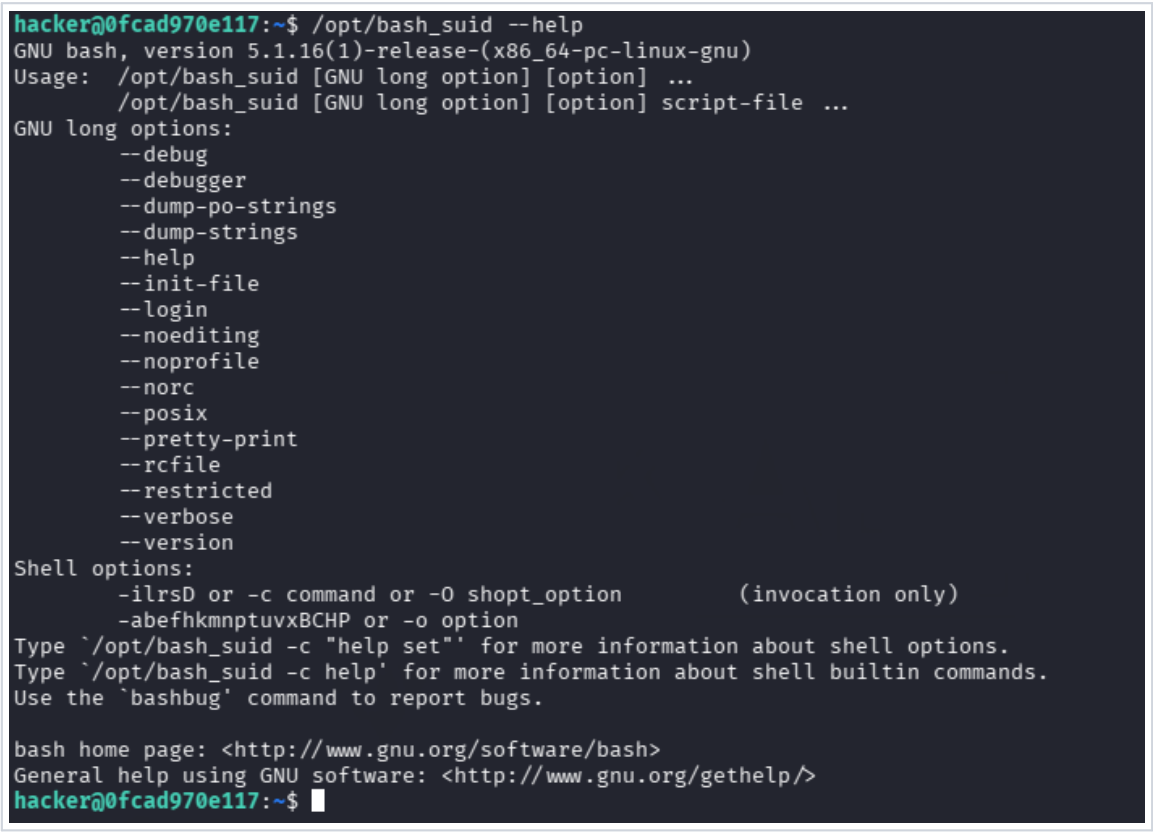


Figura 4. Ayuda de GNU bash 5.1; la opción -p permite conservar los privilegios.

Paso 5 — Explotación: obtención de root

Se invoca el binario con la opción `-p`. La shell resultante conserva `euid=0(root)`, confirmado por `id` (`uid=1000 ... euid=0(root)`) y por `whoami`, que ahora devuelve **root**. La escalada de privilegios se ha completado.

```
/opt/bash_suid -p id whoami
```

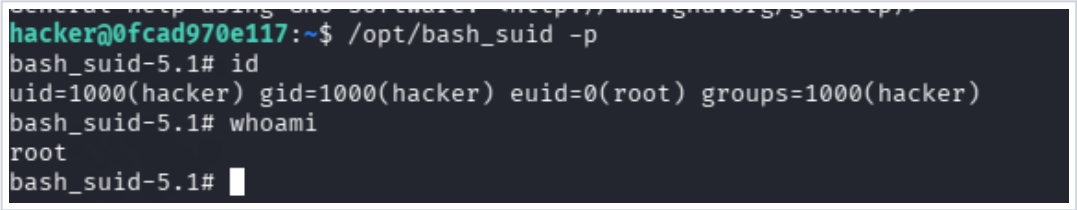


Figura 5. Con -p la shell es efectiva como root (euid=0 / whoami: root).

Paso 6 — Post-explotación: lectura de la flag

Con privilegios de root se accede al directorio `/root/` — inaccesible para un usuario normal — y se lee el fichero `flag.txt`, obteniendo la prueba de compromiso total del sistema.

```
cd /root/ ls cat flag.txt
```

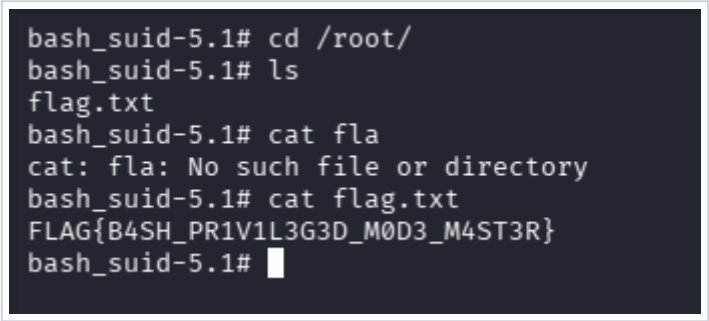


Figura 6. Lectura de /root/flag.txt — FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}.

FLAG OBTENIDA

`FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}`

4. Remediación y recomendaciones

Acciones correctivas inmediatas

- **Eliminar el bit SUID** del binario anómalo: `chmod u-s /opt/bash_suid`, o directamente borrar `/opt/bash_suid` si no tiene justificación operativa.
- **Nunca asignar SUID a shells** ni a intérpretes (bash, sh, python, perl, etc.) ni a binarios que permitan ejecución arbitraria de comandos.
- **Auditar periódicamente** los binarios SUID/SGID del sistema: `find / -perm -4000 -o -perm -2000 2>/dev/null` y comparar contra una línea base conocida.

Medidas de defensa en profundidad

- Aplicar el principio de **mínimo privilegio**: revisar qué necesita realmente privilegios elevados y por qué.
- Montar particiones de usuario con la opción `nosuid` cuando sea posible.
- Desplegar **monitorización de integridad de ficheros** (AIDE, Tripwire) para detectar binarios SUID nuevos o modificados.
- Integrar la verificación de binarios SUID en el proceso de *hardening* y en los controles de CI/CD de las imágenes base.
- Reducir la superficie: aplicar guías CIS Benchmark para el sistema operativo.

5. Conclusión

Una única configuración incorrecta — un intérprete de comandos con bit SUID propiedad de root — fue suficiente para comprometer por completo el sistema sin necesidad de credenciales ni exploits complejos. El caso ilustra por qué la enumeración local (empezando por los binarios SUID) es uno de los primeros pasos tras obtener acceso, y por qué el **hardening** y el **mínimo privilegio** son controles críticos. Retirar el bit SUID del binario corta la cadena de ataque de raíz.

Informe elaborado por **Josep Sanz** — 4 de noviembre de 2026. Documento confidencial de carácter técnico; las técnicas aquí descritas se han ejecutado en un entorno de laboratorio autorizado y controlado.